

# Metodologia Ataque de Força Bruta e Credential Stuffing

Brayan Cordeiro  
Davi Wesley  
Rafael Marinho

## 1. Apresentação Teórica

O início do trabalho se dará por meio de uma breve apresentação de tópicos teóricos, a fim de prover a base necessária para a compreensão das etapas seguintes do mesmo. Os tópicos a serem desenvolvidos decorrem de: diferenciação entre força bruta e credential stuffing; exposição de casos reais para contextualização; e meios de proteção contra ataques.

### 1.1 Força Bruta vs. Credential Stuffing

O objetivo é estabelecer a distinção fundamental entre as naturezas dos dois ataques, focando em como a origem dos dados dita o comportamento da automação.

#### 1.1.1 Ataque de Força Bruta

Ataque de Força Bruta (Brute Force): Este método baseia-se na exaustão. O atacante não possui informações prévias sobre senhas válidas. A técnica consiste em testar sistematicamente combinações de caracteres ou utilizar grandes dicionários de palavras genéricas (*wordlists*) contra um formulário de login. É um ataque tipicamente "ruidoso", gerando um volume massivo de requisições de erro no servidor alvo até que uma combinação estatisticamente provável obtenha sucesso.

#### 1.1.2 Ataque de Credential Stuffing

Diferente da força bruta, o *credential stuffing* parte de uma premissa cirúrgica: o atacante já possui dados reais. Utilizam-se listas de credenciais (pares de e-mail/usuário e senha) obtidas em vazamentos de dados de terceiros (*data breaches*). O ataque explora o comportamento humano da "fadiga de senhas" — a tendência de reutilizar a mesma senha em diferentes serviços. Como testar combinações que já foram válidas em algum lugar, a taxa de sucesso costuma ser mais alta com um número significativamente menor de requisições.

### 1.2 Casos reais de ataque

Por motivos de contextualização e imersão, serão apresentados dois casos reais de ataques, sendo o primeiro de força bruta contra a empresa Cisco em 2024 e o segundo caso a ser exposto, credential stuffing contra a empresa Roku também no ano de 2024.

O caso de força bruta contra a Cisco foi uma campanha massiva de tentativas de autenticação maliciosas identificada pela equipe Cisco Talos em abril de 2024. O objetivo dos invasores era comprometer credenciais de acesso remoto por meio de ataques automatizados de força bruta e password spraying.

Já no caso de credential stuffing onde a Roku sofreu com dois grandes incidentes, uma técnica em que criminosos utilizam combinações de usuário e senha obtidas em vazamentos de outros serviços para tentar acessar contas em uma plataforma diferente. A empresa afirmou que seus sistemas não foram invadidos; o ataque explorou credenciais reutilizadas pelos próprios usuários.

### **1.3 Formas de proteção**

A apresentação teórica será finalizada com um breve tópico sobre formas de proteção contra os dois tipos de ataques, abordando pontos como autenticação em dois fatores; Rate Limiting por IP; e o uso de senhas únicas por plataforma através de gerenciadores de senha.

## **2. Demonstração prática em laboratório**

O ambiente configurado para a demonstração prática envolve duas máquinas hospedadas na ferramenta Oracle VirtualBox. Uma máquina terá o OWASP Juice Shop em um sistema operacional ubuntu, e atuará como o ambiente de controle e validação inicial.

Por ser uma aplicação web moderna intencionalmente vulnerável e padronizada pela comunidade de segurança, ela serve para homologar as ferramentas e os scripts. Se o ataque não funcionar no Juice Shop, o problema está no vetor de ataque, não na defesa da aplicação.

Uma segunda máquina configurada com o sistema operacional kali linux, funcionará como base para todas as demonstrações de ataques. A mesma possui ferramentas que auxiliarão nesse projeto, como: Burpsuit; The Web Fuzzer; e um script python.

## **2 Execução dos Ataques**

Inicialmente será exibido a página inicial do juice shop, logo após, a simulação dos ataques se dará primeiramente através de um passo a passo com interface gráfica ferramenta Burpsuit, seguida posteriormente por uma demonstração

com o Wfuzz, onde cada parametro do comando utilizado será explicado e por fim, será exibido um script python, que pode ser utilizado para os dois casos de ataque, seja força bruta ou credential stuffing.

## **2.1 Burpsuit**

O BurpSuit é uma plataforma usada para testar a segurança de aplicações web. Ela é amplamente utilizada por profissionais de segurança, pentesters e pesquisadores para identificar vulnerabilidades em sites e APIs. Em sua essência, o BurpSuit funciona como um proxy interceptador entre o navegador e o servidor. Em vez de o navegador enviar as requisições diretamente ao site, elas passam pelo Burp, permitindo que o analista

Será apresentado para a turma as funcionalidades de proxy, onde a requisição alvo será Interceptada e modificada entre o navegador e a aplicação, junto com o intruder que automatiza o envio de múltiplas variações de uma requisição.

## **2.2 The Web Fuzzer**

O The Web Fuzzer é um recurso usado para enviar automaticamente diversas variações de entradas a uma aplicação com o objetivo de encontrar falhas, comportamentos inesperados ou vulnerabilidades, sendo uma ferramenta poderosa capaz de realizar requisições simultâneas de forma mais rápida que a versão gratuita do Burpsuit.

## **2.3 Script Python**

Por fim, será exibido um script python, linguagem utilizada para o desenvolvimento do Wfuzz, e diversas outras ferramentas. O script surge como uma alternativa de maior flexibilidade e controle, podendo ser utilizado nos dois tipos de ataque além de ser uma demonstração simples do funcionamento dessas ferramentas “por trás dos panos”.